

Assignment No. 3 (CCP)

Secure Enterprise Network Design, Threat Analysis & Cryptographic Protection

Student Name	Muhammad Irtiza
Student ID	20221-32618
Course	CSC-485 — Cyber Security
Case Organization	XYZ Solutions

Task 1: Identification of Security Problems

Network and Perimeter Weaknesses

- **No network segmentation** — HR, Finance, Dev, IT Admin, and Support share a flat network; a compromise in one department can reach all others.
- **Exposed public web application** — 120 endpoints and a public-facing app with no DMZ means the web server is a direct pivot point if breached.
- **No DDoS mitigation** — no rate-limiting, traffic scrubbing, or upstream filtering in place.
- **Weak/absent IDS/IPS** — suspicious remote access went unnoticed long enough to become an incident.

Authentication and Access Weaknesses

- **Weak passwords** — no strong policy, no account lockout, likely no MFA on VPN/remote logins.
- **Suspicious remote access attempts** — brute-force/credential-stuffing against VPN or RDP exposed to the internet.
- **No least-privilege enforcement** — flat network implies overly broad user permissions.

Communication and Data-in-Transit Weaknesses

- **Insecure wireless** — likely outdated encryption (WEP/WPA2-PSK) or no staff/guest separation.
- **Unencrypted internal communications** — credentials, file transfers, and DB queries travelling in plaintext.
- **No secure branch tunnel** — VPN link without proper IPSec leaves inter-site traffic exposed.

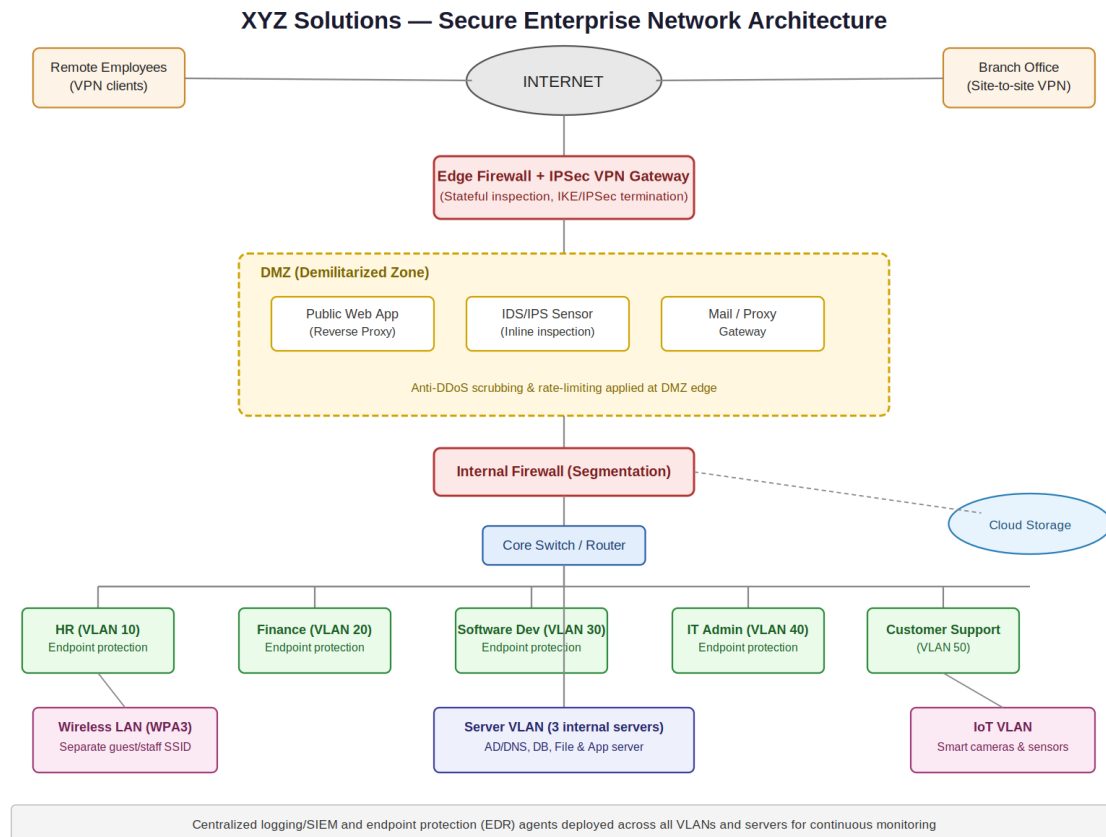
Endpoint and Human-Factor Weaknesses

- **Phishing** — no email filtering, no SPF/DKIM/DMARC, insufficient security-awareness training.
- **Malware on endpoints** — missing/outdated EDR/antivirus and no centralized patch management across 120 systems.
- **IoT blind spot** — cameras/sensors run outdated firmware and are rarely monitored or patched.
- **Cloud storage exposure** — no clear access controls or encryption at rest.

Task 2: Network Security Architecture

The design follows a layered defense-in-depth approach: internet traffic must pass through independent checkpoints before reaching sensitive resources, and departments are isolated so a breach cannot freely pivot across the organization.

Network Security Diagram



Explanation of Layered Defense

- **Edge Firewall / VPN Gateway** — First checkpoint from the internet. Performs stateful inspection and terminates IPSec tunnels for remote employees and the branch office.
- **DMZ** — Public web app, IDS/IPS sensor, and mail/proxy gateway are isolated here. Even if the web app is compromised, there is no direct path into internal segments.
- **IDS/IPS** — Inline within the DMZ and mirrored at the internal firewall — catches external attacks on the web app and lateral movement attempts.
- **Internal Firewall** — Second firewall separating DMZ from the internal network; only explicitly permitted traffic crosses this boundary.
- **VLAN Segmentation** — HR, Finance, Dev, IT Admin, and Support each sit on separate VLANs, limiting malware or compromised credentials from spreading across departments.
- **Server VLAN** — Internal servers are in their own protected VLAN, reachable only through firewall rules.
- **Wireless / IoT VLAN** — Staff wireless uses WPA3 on its own VLAN; IoT devices (cameras, sensors) are isolated to prevent them from being a pivot into employee systems.
- **Proxy Server** — Outbound web traffic is routed through a proxy/gateway for malicious-site filtering, reducing successful phishing.

- **Endpoint Protection** — EDR/antivirus agents and centralized SIEM logging deployed across all 120 endpoints, servers, and IoT devices.

Task 3: Vulnerability Assessment and Hardening

Vulnerability Area	Hardening Measures
Weak passwords / credential attacks	Strong password policy, account lockout after failed attempts, MFA on VPN/email/admin accounts
Phishing	Email filtering with SPF/DKIM/DMARC, phishing-awareness training, restrict macro execution.
Unpatched endpoints / malware	Centralized patch management, EDR/antivirus on all 120 systems, application whitelisting.
Insecure wireless	WPA3-Enterprise, disable WPS, separate guest/staff SSIDs, rotate keys periodically.
Unencrypted internal traffic	Enforce TLS for internal web services; encrypt sensitive database connections.
DDoS exposure	Rate-limiting and traffic scrubbing at edge/ISP level; connection thresholds on public-facing services
Flat network / no segmentation	VLANs per department, firewall ACLs between segments, restrict server access to required ports
IoT devices	Dedicated VLAN, disable default credentials, disable unused services, fixed firmware-patch schedule
Remote access abuse	Restrict VPN by source IP where possible, monitor login attempts, disable exposed RDP.
Cloud storage	Least-privilege access, encryption at rest, logging/alerts on file access.

Task 4: Cryptography and Secure Communication

Symmetric Encryption (AES-256)

Uses a single shared key — fast and suited to large volumes of data. AES-256 should encrypt data at rest on internal servers and cloud storage, and bulk VPN tunnel traffic once established. The key-distribution challenge is solved by asymmetric encryption.

Asymmetric Encryption (RSA/ECC)

Uses a public/private key pair. Slower than symmetric, so used selectively: exchanging symmetric session keys during IKE phase of IPSec setup, securing HTTPS for the public web app via TLS certificates, and authenticating VPN gateways before any tunnel is established.

Digital Signatures

A message hash encrypted with the sender's private key; any holder of the public key can verify authenticity and integrity. Applied at XYZ Solutions to: verify VPN gateway identity during IKE negotiation, sign software/firmware updates to prevent tampered installs, and authenticate internal emails to reduce impersonation phishing.

Mechanism	Primary Purpose	Example Use at XYZ Solutions
Symmetric (AES-256)	Confidentiality of bulk data	Encrypting VPN payload traffic and stored data

Asymmetric (RSA/ECC)	Secure key exchange & authentication	IKE key exchange, TLS for the web app
Digital Signatures	Integrity & authenticity	Verifying VPN gateway identity, signed firmware updates

Task 5: IPSec VPN Security Design

IPSec Architecture

IPSec operates at the network layer using three core protocols:

- **Authentication Header (AH)** — provides integrity and authentication, but no payload encryption.
- **Encapsulating Security Payload (ESP)** — provides confidentiality (encryption) plus optional integrity and authentication.
- **Internet Key Exchange (IKE)** — negotiates cryptographic keys before protected data is sent, establishing a Security Association (SA) between gateways.

AH vs ESP

Aspect	AH	ESP
Confidentiality (Encryption)	No	Yes
Integrity & Authentication	Yes	Yes (recommended)
Works through NAT	Generally No	Yes (NAT-Traversal)
Recommended for XYZ Solutions	Not sufficient alone	YES — primary protocol

Since the branch link needs both confidentiality and integrity and will likely pass through NAT devices, ESP is the clear choice over AH.

Tunnel Mode vs Transport Mode

Aspect	Transport Mode	Tunnel Mode
What is encrypted	Only the original IP payload	Entire original IP packet (header + payload)
Typical use	End-to-end between two hosts	Gateway-to-gateway (site-to-site VPN)
For XYZ Solutions	Not applicable here	YES — head office to branch gateway link

Recommended IPSec Configuration

- **Protocol:** ESP in Tunnel Mode (head office ↔ branch office gateways).
- **Encryption:** AES-256.
- **Integrity:** SHA-256 or stronger for HMAC checks.
- **Key Exchange:** IKEv2 with Diffie-Hellman Group 14 (2048-bit) minimum; certificate-based auth preferred over PSK.
- **Perfect Forward Secrecy (PFS):** Enabled — past and future sessions remain safe even if one key is compromised.
- **SA Lifetime:** ~1 hour with automatic IKE rekeying to limit exposure.

Key Exchange Using IKE

Phase 1 — Gateways authenticate each other (using Main Mode for security) and derive a shared secret via Diffie-Hellman exchange without transmitting it directly. **Phase 2** — Uses that secure channel to negotiate the actual IPSec SA (AH/ESP parameters for real data traffic). IKEv2 with Main Mode and certificate-based auth is recommended; it resists man-in-the-middle attacks better than Aggressive Mode or PSK alone.

Possible VPN Attacks and Mitigations

Possible Attack	Mitigation
Man-in-the-middle during key exchange	IKEv2 with certificate-based auth; verify gateway identities.
Replay attacks	Enable IPSec sequence numbers and anti-replay windows in ESP.
Brute-force on PSK (if used)	Avoid weak PSKs; prefer certificates or long random PSKs with IKEv2.
DoS on VPN gateway	Rate-limit IKE negotiations; place gateway behind edge firewall with DDoS protections.
Split-tunneling misconfiguration	Disable split tunneling so all branch traffic is forced through the encrypted tunnel.
Cipher downgrade attacks	Explicitly disable legacy algorithms (DES, MD5); enforce AES-256/SHA-256 or stronger.

IPSec Deployment Summary

Deploy a site-to-site IPSec VPN using **ESP in Tunnel Mode**, **AES-256** encryption, **SHA-256** integrity, and **IKEv2 with certificate-based authentication** and **Perfect Forward Secrecy** enabled. This protects confidentiality and integrity across the branch link, resists all common VPN attack vectors above, and integrates directly with the edge firewall/VPN gateway in the Task 2 architecture.